

Segurança da Informação

Integrantes: Dayanne Moraes, Douglas Araújo, Ewerton Monteiro, Gabriel Farias e Lucas Mateus

Autenticação e Gestão de Senhas

Neste documento detalhamos como o sistema lida com a segurança dos usuários e suas senhas.

1. Regras para Senhas

Para evitar contas fracas, o sistema exige:

- * Pelo menos 8 caracteres.
- * Letras maiúsculas e minúsculas.
- * Pelo menos um número.
- * Pelo menos um símbolo (ex: @, #, \$).

2. Como os dados são protegidos

2.1. No Servidor (Backend)

- As senhas não ficam salvas em texto comum. Usamos o algoritmo “BCrypt” para transformar a senha em um código seguro (hash) antes de salvar no banco de dados. Isso impede que alguém veja a senha original mesmo se acessar o banco.

2.2. No Aplicativo (Mobile)

- Os tokens de login ficam guardados no **SecureStore** do celular. No iPhone isso usa o Keychain e no Android usa SharedPreferences com criptografia AES-256. É muito mais seguro que o armazenamento comum.

2.3. Sessão

- Usamos tokens **JWT** para controlar quem está logado. Os tokens expiram em 1 hora para diminuir riscos caso o celular seja perdido.

3. Esqueci minha senha

Se o usuário perder o acesso:

1. Ele pede a recuperação pelo e-mail.
2. Recebe um código único para validar a identidade.
3. Cria uma nova senha dentro das regras de segurança.

Gerenciamento de Dados em Repouso e Anonimização de Informações

Neste tópico, detalhamos como o projeto protege as informações armazenadas e garante a privacidade dos usuários através de técnicas de anonimização.

1. Proteção de Dados em Repouso (Data at Rest)

Dados em repouso são as informações salvas permanentemente em discos e bancos de dados. Para garantir que esses dados não sejam acessados por pessoas não autorizadas, implementamos as seguintes camadas de segurança:

- **No Servidor (Nuvem):** Utilizamos o MongoDB Atlas, que possui criptografia nativa em repouso (AES-256). Isso garante que, mesmo que os arquivos físicos do servidor fossem acessados, os dados estariam ilegíveis sem as chaves de segurança gerenciadas pelo provedor de nuvem.
- **No Aplicativo (Mobile):** Informações sensíveis do perfil do MEI e tokens de sessão são armazenados utilizando o Expo SecureStore. Diferente do armazenamento comum, o SecureStore utiliza o Keychain (iOS) e o Keystore (Android), que guardam os dados de forma criptografada e vinculada ao hardware do dispositivo.
- **Banco de Dados Local (Cache):** Dados cacheados no SQLite local do pipeline de dados são limitados a informações públicas de licitações, evitando o armazenamento local de dados sensíveis de usuários.

2. Anonimização e Mascaramento de Informações

Para cumprir as boas práticas de segurança e reduzir o risco de exposição de dados, aplicamos as seguintes técnicas:

- **Mascaramento de Exibição:** Em telas de perfil, suporte ou logs de sistema, dados sensíveis como CPF, CNPJ e e-mail são mascarados.
Exemplo: 123.***.***-90 ou lu***@email.com. Isso impede que um "curioso" veja os dados completos ao olhar para a tela.
- **Anonimização para Análise:** Para a geração de relatórios de BI e dashboards de licitações (como os gerados pelo PySpark), os dados passam por um processo de desidentificação. Estatísticas de uso são agregadas por região ou setor, sem que seja possível identificar qual MEI específico realizou determinada busca.
- **Logs Seguros:** Nosso pipeline de logs foi configurado para filtrar e não registrar informações de autenticação ou dados pessoais sensíveis, garantindo que os registros de erro foquem apenas na depuração técnica.

Atendimento aos Requisitos da LGPD (Lei Geral de Proteção de Dados)

O projeto foi desenvolvido seguindo os princípios de Privacy by Design, garantindo que a conformidade com a LGPD (Lei nº 13.709/2018) esteja presente desde as primeiras linhas de código.

1. Transparência e Consentimento

Para garantir que o usuário tenha total controle sobre seus dados pessoais, implementamos:

- **Termos de Uso e Política de Privacidade:** Logo no primeiro acesso (Onboarding), o usuário é apresentado aos termos de uso. O aplicativo detalha quais dados são coletados (como CNPJ, e-mail e preferências de licitação) e para qual finalidade específica.
- **Gestão de Consentimento:** O processamento de dados só ocorre após o aceite explícito do usuário. No cadastro, utilizamos campos de "checkbox" claros para que o usuário autorize o uso de suas informações para a finalidade de busca e alerta de editais.

2. Direitos dos Titulares de Dados

O sistema foi estruturado para atender aos direitos previstos no Artigo 18 da LGPD:

- **Direito de Acesso e Correção:** O usuário possui uma tela de "Perfil" onde pode visualizar todos os seus dados cadastrados no sistema e realizar correções de forma autônoma.
- **Direito à Exclusão (Direito ao Esquecimento):** Implementamos uma funcionalidade de "Excluir Conta". Quando acionada, o sistema realiza o soft delete ou a deleção definitiva dos dados pessoais do banco de dados (MongoDB), garantindo que as informações do usuário não permaneçam nos servidores após o encerramento da relação.
- **Portabilidade:** Os dados de licitações favoritas e documentos do MEI são organizados de forma que o usuário possa exportar ou visualizar suas informações de maneira estruturada.

3. Minimização e Finalidade

Coleta Seletiva: O LicitaMEI coleta apenas o estritamente necessário para o funcionamento do serviço (princípio da necessidade). Não solicitamos dados que não possuam relação direta com a busca de licitações governamentais.

- **Finalidade Específica:** Os dados do MEI são utilizados exclusivamente para cruzar o perfil do empreendedor com as oportunidades do PNCP, não sendo compartilhados com terceiros para fins publicitários.

Disponibilidade e Proteção contra Ataques Digitais

Para garantir que esteja sempre acessível aos empreendedores e protegida contra intenções maliciosas, adotamos estratégias de segurança em camadas.

1. Proteção contra Ataques de Força Bruta (Brute Force)

- **Rate Limiting:** Implementamos limites de tentativas de login. Caso um usuário erre a senha consecutivamente em um curto período, o sistema bloqueia temporariamente novas tentativas para aquele IP ou conta, frustrando ataques automatizados de adivinhação de senhas.
- **Bloqueio de IP:** Monitoramos requisições suspeitas e possuímos a capacidade de bloquear IPs que demonstrem comportamento de robôs (bots) tentando sobrecarregar o sistema.

2. Segurança na Comunicação (Man-in-the-Middle)

- **Criptografia em Trânsito (HTTPS):** Toda a comunicação entre o aplicativo mobile e os servidores (API/MongoDB) é protegida pelo protocolo TLS/SSL. Isso garante que os dados não possam ser interceptados ou alterados durante o trajeto pela internet.
- **Headers de Segurança:** Configuramos o servidor para utilizar cabeçalhos de segurança que impedem ataques comuns de navegador e garantem que apenas o nosso aplicativo oficial consiga consumir os dados da API.

3. Proteção contra Injeção de Dados (SQL e NoSQL Injection)

- **Sanitização de Inputs:** Todas as entradas de dados feitas pelo usuário (como termos de busca e campos de cadastro) são validadas e "sanitizadas" antes de chegarem ao banco de dados. Isso impede que atacantes tentem executar comandos maliciosos para roubar informações.
- **Uso de ORM/ODM:** Utilizamos bibliotecas modernas para interação com o banco de dados que, por padrão, tratam os dados de forma segura, evitando brechas de injeção.

4. Disponibilidade do Serviço

- **Alta Disponibilidade (HA):** Ao utilizar serviços em nuvem (como MongoDB Atlas), os dados são replicados em diferentes servidores. Se um servidor cair, outro assume automaticamente, garantindo que o LicitaMEI continue online 24/7.
- **Escalabilidade:** A infraestrutura foi desenhada para suportar picos de acesso (como quando um edital muito importante é publicado) sem que o sistema sofra lentidão ou quedas.

Backup e Continuidade de Operação

A resiliência dos dados é fundamental. Implementamos políticas rigorosas de backup e planos de recuperação para garantir que nenhuma oportunidade de negócio seja perdida em caso de falhas técnicas.

1. Política de Backup Automatizado

- **Backups Diários:** Configuramos o MongoDB Atlas para realizar backups automáticos de toda a base de dados uma vez por dia. Esses snapshots são armazenados em locais geograficamente distintos do servidor principal.
- **Retenção de Dados:** Mantemos as cópias de segurança por um período de 30 dias. Isso permite que, caso ocorra um erro humano ou corrupção de dados, possamos "voltar no tempo" para uma versão íntegra do sistema.
- **Testes de Restauração:** Realizamos testes periódicos de restauração de backup para garantir que os arquivos salvos estão funcionando e que o tempo de recuperação (RTO) seja o menor possível.

2. Continuidade de Operação (Disaster Recovery)

- **Redundância Geográfica:** Os dados e serviços estão hospedados em provedores de nuvem de primeira linha. No caso de uma queda total de um Data Center em uma região, o sistema possui capacidade de ser reestabelecido em outra região em poucos minutos.
- **Isolamento de Erros:** Nosso pipeline de orquestração (Prefect) foi desenhado para isolar falhas. Se a extração de dados do governo falhar, os dados que já estão no banco de dados continuam disponíveis para os usuários, garantindo que o aplicativo nunca fique "vazio".
- **Plano de Contingência:** Em caso de manutenção programada ou falha crítica, o sistema está preparado para exibir mensagens informativas aos usuários no aplicativo mobile, mantendo a transparência sobre o status da operação.
-

3. Integridade dos Dados

- **Versionamento de Código:** Todo o código do sistema e as configurações de infraestrutura são versionados no GitHub. Isso garante que possamos recuperar o ambiente completo em uma nova máquina rapidamente se necessário.
- **Consistência:** Utilizamos transações e validações de integridade no banco de dados para evitar que falhas de conexão gerem dados "quebrados" ou incompletos durante o processo de ETL.

Gestão de Fornecedores

Como utilizamos diversos serviços e bibliotecas externas para funcionar, estabelecemos uma política de gestão de fornecedores focada em confiança, segurança e conformidade técnica.

1. Seleção de Provedores de Infraestrutura

- **Padrões Globais:** Optamos por parceiros que são líderes de mercado e possuem as certificações de segurança mais rigorosas do mundo (como ISO 27001 e SOC 2).
- **Provedores Utilizados:** MongoDB Atlas (Database as a Service): Responsável por todo o armazenamento em nuvem.
- **GitHub:** Utilizado para hospedagem segura do código-fonte e colaboração da equipe.
- **PNCP (Governo Federal):** Nossa fonte primária de dados. Mantemos o monitoramento constante da disponibilidade desta API governamental.

2. Gestão de Dependências e Bibliotecas (Supply Chain Security)

- **Bibliotecas Open Source:** No desenvolvimento mobile (React Native/Expo) e de dados (Python/Prefect/Spark), só utilizamos bibliotecas com ampla adoção pela comunidade e histórico positivo de manutenção.
- **Atualização Periódica:** Temos um processo de revisão semanal para verificar se existem novas versões das bibliotecas. O objetivo é aplicar "patches" de segurança o mais rápido possível para evitar vulnerabilidades conhecidas (CVEs).
- **Análise de Vulnerabilidade:** Utilizamos ferramentas automáticas do GitHub (como o Dependabot) que nos alertam imediatamente caso alguma biblioteca que usamos apresente um risco de segurança.

3. Acordos de Nível de Serviço (SLA)

- **Disponibilidade:** Ao contratar serviços em nuvem, priorizamos aqueles que oferecem garantias de disponibilidade acima de 99,9%. Isso transfere parte da responsabilidade de infraestrutura para especialistas, permitindo que a equipe foque na regra de negócio do LicitaMEI.
- **Segurança de Dados:** Todos os nossos fornecedores de nuvem garantem contratualmente a conformidade com leis internacionais de proteção de dados e com a LGPD brasileira, assegurando que as informações do nosso banco não sejam acessadas por terceiros.